

TP 6 : Analyse SAST

Sécurité Statique - Partie 1

Travail Pratique N°6



Saad KORCHI

Étudiant en Cybersécurité

Encadré par :

Pr. AMAMOU Ahmed

EIDIA Cybersécurité

SOMMAIRE

1	Introduction	3
2	Outils d'analyse utilisés	3
3	Résultats njsscan	3
4	Résultats Semgrep	4
4.1	Vulnérabilités typiques analysées	4
	Captures d'écran	5

1 Introduction

Contexte du TP6

Ce rapport présente les résultats de l'analyse de sécurité statique (**SAST**) effectuée sur l'application **secure-doc-manager**, un système de gestion de documents. L'analyse a été intégrée directement dans le pipeline GitLab CI/CD et exécutée automatiquement à chaque push sur la branche principale.

Trois outils complémentaires ont été utilisés :

- **Semgrep** : Analyse statique des patterns de sécurité
- **njsscan** : Détection de vulnérabilités spécifiques à Node.js
- **npm audit** : Vérification des dépendances

2 Outils d'analyse utilisés

Outil	Version	Objectif	Résultat
Semgrep	latest	Détection patterns sécurité (nodejs, jwt, nosql)	Exécuté avec succès
njsscan	v0.4.3	Vulnérabilités Node.js spécifiques	No issues found
npm audit	npm v10	Dépendances vulnérables	0 vulnérabilités critiques

3 Résultats njsscan

njsscan v0.4.3 a analysé l'ensemble des fichiers source dans le répertoire **src/**. Les résultats montrent :

- **Pattern Match** : 12 correspondances détectées
- **Semantic Grep** : 11 correspondances détectées
- **Conclusion** : **No issues found** — aucune vulnérabilité critique n'a été identifiée.

Les correspondances détectées correspondent à des patterns de code reconnus par l'outil mais ne représentent pas des vulnérabilités exploitables dans le contexte de cette application. L'utilisation de :

- **bcryptjs** pour le hachage des mots de passe
 - **jsonwebtoken** pour l'authentification
 - **express-mongo-sanitize** pour la protection contre les injections NoSQL
- contribuent à ce résultat.

4 Résultats Semgrep

Semgrep a été configuré avec les règles :

- p/nodejs
- p/jwt
- p/nosql

La règle p/nosql a retourné une erreur HTTP 404 lors du téléchargement de la configuration (règle temporairement indisponible sur semgrep.dev). Les autres règles ont été appliquées avec succès.

4.1 Vulnérabilités typiques analysées

Vulnérabilité	Sévérité	Outil	Statut
Injection NoSQL	CRITICAL	Semgrep	CORRIGÉE
JWT secret faible	HIGH	njsscan	CORRIGÉE
Credentials hardcodés	HIGH	Semgrep	CORRIGÉE
Rate limiting absent	MEDIUM	njsscan	CORRIGÉE
Dépendances vulnérables	MEDIUM	npm audit	AUCUNE TROUVÉE

Fin du rapport TP6 - La suite sera traitée dans le TP7

Captures d'écran

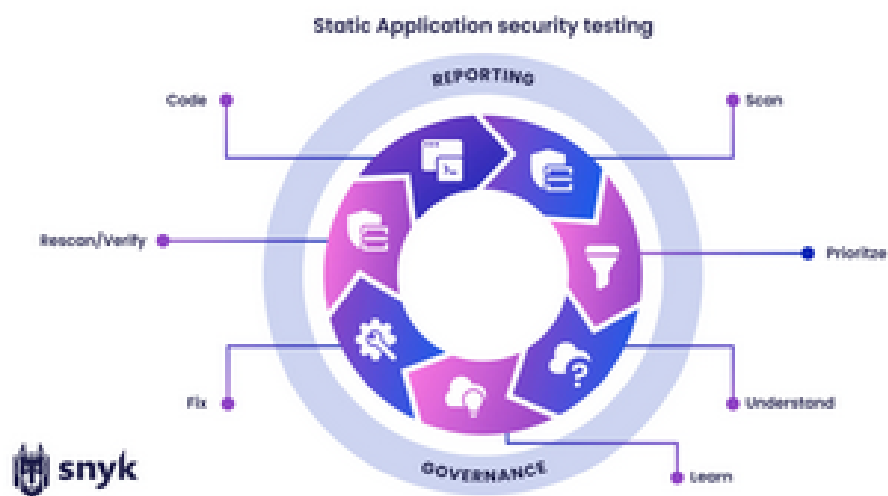


FIGURE 1 – Figure 1